

AI Prompts Used - using Github Copilot

Threat Insights

Global cyber-attack dataset (2015-2024)

- The dataset contains 3,000 recorded attacks and approximately 151,478.91 million in total financial loss.
- DDoS is the most frequent attack type with 531 incidents, followed by phishing with 529 and SQL injection with 503.
- DDoS also produced the highest total financial loss at approximately 27,630.92 million. Phishing ranked second at approximately 26,693.29 million.
- The United Kingdom recorded the most attacks with 321, followed by Brazil with 310 and India with 308.
- IT was the most targeted industry with 478 attacks. Banking followed with 445 and healthcare with 429, showing elevated exposure in technology-dependent and data-sensitive sectors.
- Zero-day vulnerabilities were the most frequently recorded security vulnerability type with 785 cases, followed by social engineering with 747 and unpatched software with 738.
- Antivirus was the most commonly reported defense mechanism with 628 uses, followed by VPN with 612 and encryption with 592.
- Man-in-the-Middle attacks had the highest average number of affected users at approximately 520,064, while phishing had the lowest among the listed attack types at approximately 487,179.
- Attack volumes fluctuated across the period rather than following a steady trend. The highest annual count was in 2017 with 319 attacks, while 2019 was the lowest with 263.

NVD CVE dataset

- The extract contains 100 CVE records with an average CVSS score of approximately 9.10 for the records with available scores.
- Only two records have populated severity labels: one CRITICAL and one HIGH. The remaining 98 records have missing severity values, so the severity distribution is incomplete.
- CVE-1999-0066 is the highest-scoring listed vulnerability with a CVSS score of 9.8 and a CRITICAL label. CVE-1999-0084 follows with a score of 8.4 and a HIGH label.
- The published CVE records span 1988-1995 in this extract. This historical range should not be interpreted as a current-year vulnerability trend without a more recent and complete NVD sample.

Risk Assessment

Overall risk

The organization faces a high cyber-risk environment because the most common threats are also financially material. DDoS and phishing together account for 1,060 of 3,000 attacks, or approximately 35.3% of all incidents, and are the two largest contributors to total financial loss.

Priority risk areas

1. **Availability risk:** DDoS is the leading attack type by volume and total loss, creating a direct threat to service uptime and business continuity.
2. **Human and identity risk:** Phishing is nearly as frequent as DDoS and is closely associated with credential theft, account compromise, and social engineering.
3. **Application risk:** SQL injection represents 503 incidents, indicating a material need for secure software development and database protection.
4. **Sector concentration:** IT, banking, and healthcare are the three most targeted industries. Their dependence on availability, sensitive data, and interconnected systems increases potential impact.
5. **Vulnerability management risk:** Zero-day vulnerabilities and unpatched software are prominent vulnerability categories. The NVD sample cannot currently support a reliable severity assessment because most severity fields are null.
6. **Large-scale impact risk:** Man-in-the-Middle attacks affected the highest average number of users, suggesting that attacks against communications and trust relationships can have broad reach even when their incident count is lower.

Recommendations

1. **Prioritize DDoS resilience:** Use upstream DDoS protection, traffic scrubbing, rate limiting, redundant hosting, autoscaling, and tested continuity procedures for critical services.
2. **Strengthen phishing resistance:** Require phishing-resistant MFA for privileged and high-risk accounts, deploy email authentication controls such as SPF, DKIM, and DMARC, and run targeted awareness exercises with measurable reporting.
3. **Reduce exploitable application flaws:** Adopt secure coding standards, parameterized queries, automated SAST/DAST testing, code review, web application firewalls, and regular penetration testing for systems exposed to the internet.
4. **Improve patch and exposure management:** Maintain an accurate asset inventory, prioritize internet-facing and actively exploited vulnerabilities, define patching SLAs, and track exceptions to closure.
5. **Protect communications:** Use strong encryption, certificate validation, secure DNS, VPN controls, network segmentation, and monitoring for unusual session or certificate behavior to reduce Man-in-the-Middle exposure.
6. **Protect high-risk industries and data:** Apply least privilege, privileged access management, encryption at rest, immutable backups, and tested incident-response playbooks for IT, banking, and healthcare environments.

7. **Measure response performance:** The average incident resolution time is approximately 36 hours. Establish recovery-time targets, automate alert triage, and conduct post-incident reviews to reduce containment and recovery time.
8. **Improve CVE data quality:** Refresh the NVD integration with current records, populate missing CVSS and severity fields where available, retain publication and modification dates, and distinguish missing values from zero or unknown scores before making risk decisions.

Future Trends

- DDoS and ransomware-style disruption are likely to remain significant as organizations become more dependent on online services and distributed infrastructure.
- Phishing is likely to become more convincing through automation and generative AI, increasing the need for phishing-resistant authentication and identity monitoring.
- The continued use of cloud services, APIs, and interconnected applications will increase the importance of API security, identity controls, zero-trust segmentation, and software supply-chain monitoring.
- Zero-day exploitation and delayed patching will remain high-impact risks, especially for internet-facing systems and widely deployed third-party components.
- Attackers will continue targeting high-value industries such as IT, banking, and healthcare because operational disruption and data theft can produce substantial financial and strategic impact.
- Security analytics and AI-based detection may improve detection speed, but automated decisions should be supported by human validation, explainable alerting, and controls against poisoned or manipulated data.
- A complete, current NVD dataset is required for reliable forecasting. The current 100-record extract is too small, too historical, and too incomplete in severity fields to establish a dependable CVE trend.

Analysis Caveats

- Financial loss is reported in millions and should be labeled clearly in any dashboard or presentation.
- The average CVSS calculation excludes null scores; it should not be presented as the average severity of all 100 records.
- The displayed CVE severity counts sum to 100, but only two records have a known severity classification.
- The “Highest Affected Users” query uses ascending order. Based on the displayed values, Man-in-the-Middle is the highest and phishing is the lowest; use descending order when reproducing the top-10 result.
- These findings describe associations in the supplied datasets and do not establish that one attack type caused a particular financial loss or resolution time.